



C 类零部件通用信息安全技术要求

General Information Security Technical Requirements for Components

目 次

目 次.....	1
1 范围.....	2
2 规范性引用文件.....	2
3 术语和定义.....	2
3.1 缩略语.....	2
3.2 术语定义.....	2
4 技术要求.....	3
4.1 硬件安全.....	3
4.1.1 PCB 硬件强化.....	3
4.2 系统安全.....	3
4.2.1 系统代码安全.....	3
4.3 安全软件升级.....	3
4.3.1 软件逻辑块签名.....	3
4.3.2 软件逻辑块验签.....	4
4.3.3 安全升级校验算法.....	4
4.3.4 密钥管理.....	4
4.4 安全诊断.....	4
4.4.1 安全认证.....	4
4.4.2 密钥管理.....	4
4.5 信息安全测试.....	4

DFCV C 类零部件信息安全技术要求

1 范围

本文件给出东风商用车C类控制器信息安全需求，旨在提供信息安全要求及参考相关的必要、充分和支持性信息。

本文件适用于东风商用车C类控制器信息安全开发的技术输入文件。

2 规范性引用文件

ISO SAE 21434-2021 Road vehicles - Cybersecurity engineering

GB/T 40861-2021 汽车信息安全通用技术要求

GB/T 40856-2021 车载信息交互系统信息安全技术要求及试验方法

GB/T 40855-2021 电动汽车远程服务与管理系统信息安全技术要求及试验方法

GM/T0028 密码模块安全技术要求

NIST SP 800-90A Recommendation for Random Number Generation 随机数发生器建议

3 术语和定义

3.1 缩略语

PCB: Printed Circuit Board 印刷电路板

ECU: Electronic Control Unit 电子控制单元

HSM: Hardware Security Module 硬件安全模块

AES: Advanced Encryption Standard 高级加密标准

RSA: 公开密钥密码体制

ECC: Elliptic curve cryptography 椭圆曲线公开密钥密码体制

SHA: Secure Hash Algorithm 安全散列算法

CMAC: CBC-Message Authentication Code 分组密码的消息验证码

HMAC: Hash Message Authentication Code 散列算法的消息验证码

3.2 术语定义

完整性 Integrity

确保信息在存储、使用、传输过程中不会被非授权用户篡改，同时还要防止授权用户对系统及信息进行不恰当的篡改，保持信息内、外部表示的一致性。

真实性 Authenticity

一个实体是其所声称实体的特性。

4 技术要求

4.1 硬件安全

4.1.1 PCB 硬件强化

硬件强化是在产品设计初始阶段就需要开始导入的一些基础硬件设计。硬件强化的目的是限制攻击者轻易获取到的信息的数量。合理硬件设计背后的理念是保护和限制对软件的访问权限。目标是尽可能提高任何硬件攻击的难度和耗时。可以从以下几个措施实施硬件强化：

1) 丝印和标记

在生产PCB时，时常会对部件进行标号。PCB上这些印刷的内容和标记在产品开发阶段有助于开发人员识别，但在最终量产的PCB上需要移除这些印刷内容和标号。这些印刷内容和标号会帮助攻击者识别集成电路的功能，设备的引脚分配或调试端口。攻击者可以利用这些信息来获取设备的未经授权的访问权限。

推荐措施：

措施：

- 量产的PCB，优先不使用丝印标记；
- 量产的PCB，在必须使用丝印标记时，所有部件需进行标记且应使用已编码的标号，编码信息需要保密。

2) 调试接口

移除量产PCB板上调试接口。

如果无法移除，则要求进行访问控制（密码应满足密码强度要求：不少于8个字符）。

4.2 系统安全

4.2.1 系统代码安全

1) 编码规范

软件编码须符合 MISRA C 2012 或 CERT C 2016 规范；

2) 源代码安全

使用静态代码分析工具对源代码进行信息安全扫描，并提供测试报告。

4.3 安全软件升级

如有软件升级功能，需实现安全软件升级要求。

4.3.1 软件逻辑块签名

ECU 软件可能包含多个逻辑块，每个软件部分为一个逻辑块，每个软件逻辑块需要单独签名，且需保证完整性和真实性。

如：对逻辑块的哈希值进行签名。

4.3.2 软件逻辑块验签

如果签名验证失败，则应触发重新刷新或者回滚，确保软件处于安全可用的状态。

4.3.3 安全升级校验算法

如果 ECU 具备 HSM 且支持非对称算法，软件校验需在 HSM 中执行，校验算法优先推荐使用 Elliptic Curves with $p \geq 256$ 。如果不支持 ECC 可使用 RSA2048+SHA256；

如果 ECU 具备 HSM 仅支持对称算法，软件校验需在 HSM 中执行，校验算法优先推荐使用 HMAC/CMAC；

如果 ECU 无 HSM，校验算法可使用通过软件算法库实现的 HMAC/CMAC；

如使用其他安全算法，需与 DFCV 沟通确认。

4.3.4 密钥管理

在开发和测试过程中会使用密钥和正式量产的密钥区分开，开发测试密钥不能用作量产产品密钥。

安全升级 ECU 校验的密钥生成、分发、使用，密钥灌装、密钥更新和删除机制等由零部件供应商提供，这些机制必须经过 DFCV 评审。

应采取安全访问技术或安全存储技术保护存储的密钥。

4.4 安全诊断

如有诊断功能，需实现安全诊断需求。

4.4.1 安全认证

ECU 安全访问认证服务的算法采用 AES128-CBC。如使用其他安全算法，需与 DFCV 沟通确认。

对于诊断双方的身份认证，ECU 端应支持认证失败处理机制，增加暴力破解难度。

4.4.2 密钥管理

在开发和测试过程中会使用密钥和正式量产的密钥区分开，开发测试密钥不能用作量产产品密钥。

安全升级 ECU 校验的密钥生成、密钥灌装、密钥更新和删除机制由零部件供应商提供，这些机制必须经过 DFCV 评审。

应采取安全访问技术或安全存储技术保护存储的密钥。

4.5 信息安全测试

需完成信息安全需求符合性验证测试，并提供测试报告交由 DFCV 审核。